

# Windows

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

## Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

## Señales

- whoami /priv revela un privilegio potente (SeImpersonate, SeBackup, SeDebug).
- WinPEAS resalta servicios modificables o rutas sin comillas.
- accesschk o WinPEAS marca SERVICE\_CHANGE\_CONFIG o WRITE sobre un servicio.
- El .exe del servicio esta en una carpeta escribible por tu usuario.
- SeImpersonatePrivilege = Enabled en whoami /priv.
- Tu usuario es un service account (iis apppool..., mssql, local service).

## Comandos y pruebas

| Prueba                                                                       | Objetivo/contexto                                                                                                                                          | Evidencia esperada                                                                                                                                             |
|------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| whoami /priv                                                                 | Lista tus privilegios de token, el vector mas rapido en Windows. Varios (SeImpersonate, SeBackup, SeRestore, SeDebug) llevan a SYSTEM casi directo.        | Privilegios y si estan Enabled. SeImpersonate -> token-impersonation. SeBackup/SeRestore -> sebackup-serestore. Anota los que estan habilitados.               |
| systeminfo                                                                   | Muestra version de Windows y hotfixes instalados. Comparar los parches con los CVE conocidos revela si hay un exploit de kernel aplicable.                 | OS version, build y lista de KB (parches). Pocos KB en un Windows viejo -> candidato a exploit de kernel; pasalo por Watson/wesng.                             |
| sc qc <servicio>                                                             | Muestra la configuracion del servicio: su BINARY_PATH_NAME y la cuenta con la que corre. Ahi ves si la ruta esta sin comillas y si corre como LocalSystem. | BINARY_PATH_NAME (mira comillas y espacios) y SERVICE_START_NAME (LocalSystem = SYSTEM). Combinar con accesschk revela si puedes modificarlo.                  |
| sc config <servicio> binPath="C:\Windows\Temp\pe.exe" && sc start <servicio> | Si tienes SERVICE_CHANGE_CONFIG, reescribes que ejecuta el servicio y lo arrancas: tu binario corra como SYSTEM. Es el abuso mas directo.                  | El servicio ejecuta tu pe.exe como SYSTEM (crea un usuario admin o lanza tu shell). Si no puedes cambiar config, prueba reemplazar el .exe o el unquoted path. |
| PrintSpoofer64.exe -i -c cmd                                                 | Abusa de SeImpersonate forzando al spooler a autenticarse contra el exploit y suplantando su token SYSTEM. -i abre una consola interactiva como SYSTEM.    | Un cmd nuevo donde whoami dice 'nt authority\system'. Si falla por version/parcheo del spooler, prueba GodPotato o JuicyPotato segun el Windows.               |

## Diagnóstico

| Síntoma           | Comprobar                                  |
|-------------------|--------------------------------------------|
| Sin respuesta     | ruta, DNS, puerto, listener y firewall     |
| Rechazo           | sintaxis, credenciales, permisos y versión |
| Salida distinta   | control negativo, caché y estado           |
| Resultado parcial | identidad efectiva y condiciones           |

## Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: [conceptos de Fieldbook](#). Método: [construcción de payloads](#).